

Pwnable(시스템 해킹 1차 과제)

드림핵

이 부분에 대해선 자료 작성하지 않으셔도 괜찮습니다.

아래 드림핵이라는 사이트를 참고하실것을 추천드립니다. 추가로 구글링도 많이 해보셔야 이해가 쉬워집니다.

<https://dreamhack.io/>

리눅스(우분투 22.04) 환경구축하고 리눅스 다뤄보기 (VMware, WSL등등)

Pwntools, pwndbg설치 및 사용법 숙지

문제실습

<https://dreamhack.io/wargame/challenges/410>

실습 진행하시면서 어렵거나 막히는 부분이 많이 있을거라 예상됩니다. 너무 오래 걸린다 싶으면 답지를 찾아보는것도 괜찮습니다.

단, 본인이 작성한 코드에 대해서 상세하게 분석해서 설명을 적어주세요.

reversing 과제 1

reversing

- 리버싱 분석 방법
- IDA, x64dbg 사용방법
- CPU 레지스터 IA - 32레지스터 구조
- 스택 프레임의 구조
- 함수 호출 규약
- 어셈블리어

각각 키워드에 대해 조사하고 보고서로 제출.

문제 풀이

첫 번째 문제는 가려진 flag를 찾으시면 됩니다.

[934d6616-e9d4-4173-baec-2de2ea029b91.zip](#)

두 번째 문제는 라이브러리 함수로 생성된 flag를 찾으시면 됩니다.

libbabyanalysis.zip

되도록 IDA 사용을 추천드립니다.

reversing 과제 2

어셈블리어로 echo 프로그램 작성

어셈블리 에디터로 입력한 문자열을 그대로 출력하는 프로그램을 만들어주세요.

```
glntnd02@DESKTOP-7QC...:~$ ./echo
Hello World
Hello World
glntnd02@DESKTOP-7QC...:~$ ./echo
Security Fact
Security Fact
```

작성한 코드 한 줄씩 주석 달아주세요.

- syscall의 의미
- 각 명령어의 역할을 자세하게

코드 실행 시 출력되는 결과

main:

```
push rbp
mov rbp, rsp
mov esi, 0x20
mov rdi, 0x401800
call 0x401797 <write_n>
mov eax, 0x0
pop rbp
ret
```

write_n:

```
push rbp
mov rbp, rsp
mov QWORD PTR [rbp-0x8], rdi
mov DWORD PTR [rbp-0xc], esi
xor rdx, rdx
mov edx, DWORD PTR [rbp-0xc]
mov rsi, QWORD PTR [rbp-0x8]
mov rdi, 0x1
mov rax, 0x1
syscall
pop rbp
ret
```

=====

[Memory]

0x401800		0x4920216f31316568
0x401808		0x7373612073312074
0x401816		0x336420796c366d33
0x401824		0x00676e3136367562

한 줄씩 주석 달면서 설명을 적어주시고
이 코드를 실행하면 출력되는 문자열을 적어주세요.

- Forensic(1,2)

1. Event Log

- Event Log란 무엇인가
- Windows 계정 생성, 로그인 관련 이벤트 로그 전수 조사
- 첨부된 Event Log Problem.zip 풀이
 - 단순 풀이가 아닌, 사고 흐름 위주로 상세하게 작성. → 최대한 풀어보도록 노력하고 사고 흐름(왜 정답이라고 생각하는지 혹은 왜 애매하다고 생각하는 지 등)을 작성.

2. 메모리 포렌식

- 메모리 포렌식이란 무엇인가
- Volatility의 모든 것(사용 방법, 프로필, 등...)
- [Cyberdefenders.org](https://www.cyberdefenders.org) → Labs → Reveal 문제 풀이
 - 단순 풀이가 아닌, 사고 흐름 위주로 상세하게 작성. → 최대한 풀어보도록 노력하고 사고 흐름(왜 정답이라고 생각하는지 혹은 왜 애매하다고 생각하는 지 등)을 작성.

웹 개발 및 sql injection실습

목표

SQL Injection 공격을 이해하고 실습하기

조건

1. 기본 로그인 기능 구현

- 사용자의 ID와 PW를 입력 받아서 SQL 쿼리를 실행하여 로그인하는 웹을 구현합니다.
- 계정 정보는 간단한 DB 파일에서 가져옵니다.

2. 데이터베이스

- ID와 PW가 저장되어 있는 DB 파일입니다.
- 관리자의 계정 ID와 PW는 `admin`으로 고정되어 있습니다.

3. 웹 구현

- 사용 언어와 디자인은 자유롭게 선택합니다.
- 웹은 로컬 환경에서만 실행되면 됩니다.
- 추가적인 제한 사항 없이 위의 기능들만 존재하면 됩니다.

4. SQL Injection 실습

- SQL Injection 공격을 최소 2가지 방법으로 실습합니다.
- *** 예시로 주어진 구문은 제외합니다 ***

추가 사항

- 어떻게 하면 공격을 방지할 수 있는지, 다른 우회 방법은 무엇이 있는지 조사해보기

제출

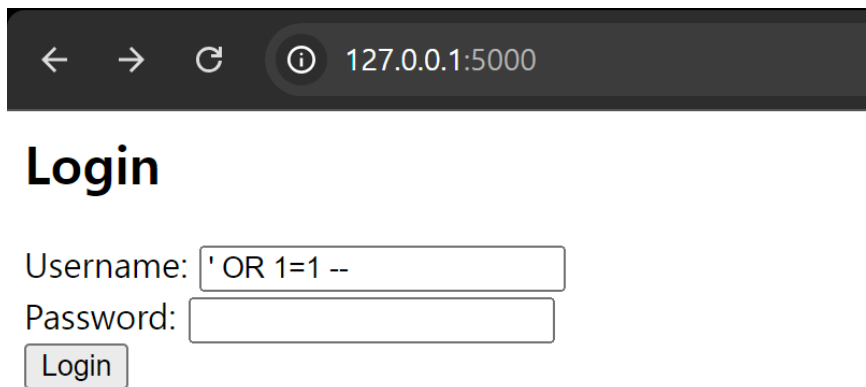
- 캡처 화면 및 소스 코드, 과제에 대한 간단한 설명(PDF) 압축 후 제출

확인 기준

1. admin/admin 으로 로그인 기능이 잘 실행되는가?
2. SQL injection 공격을 제대로 수행했는가?

과제 예시)

로그인 화면



← → ↻ ⓘ 127.0.0.1:5000

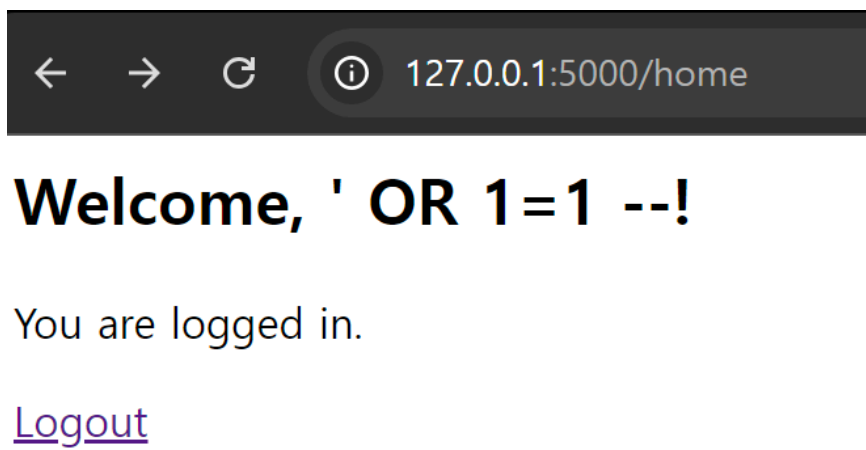
Login

Username:

Password:

Login

SQL injection 공격



← → ↻ ⓘ 127.0.0.1:5000/home

Welcome, ' OR 1=1 --!

You are logged in.

[Logout](#)